



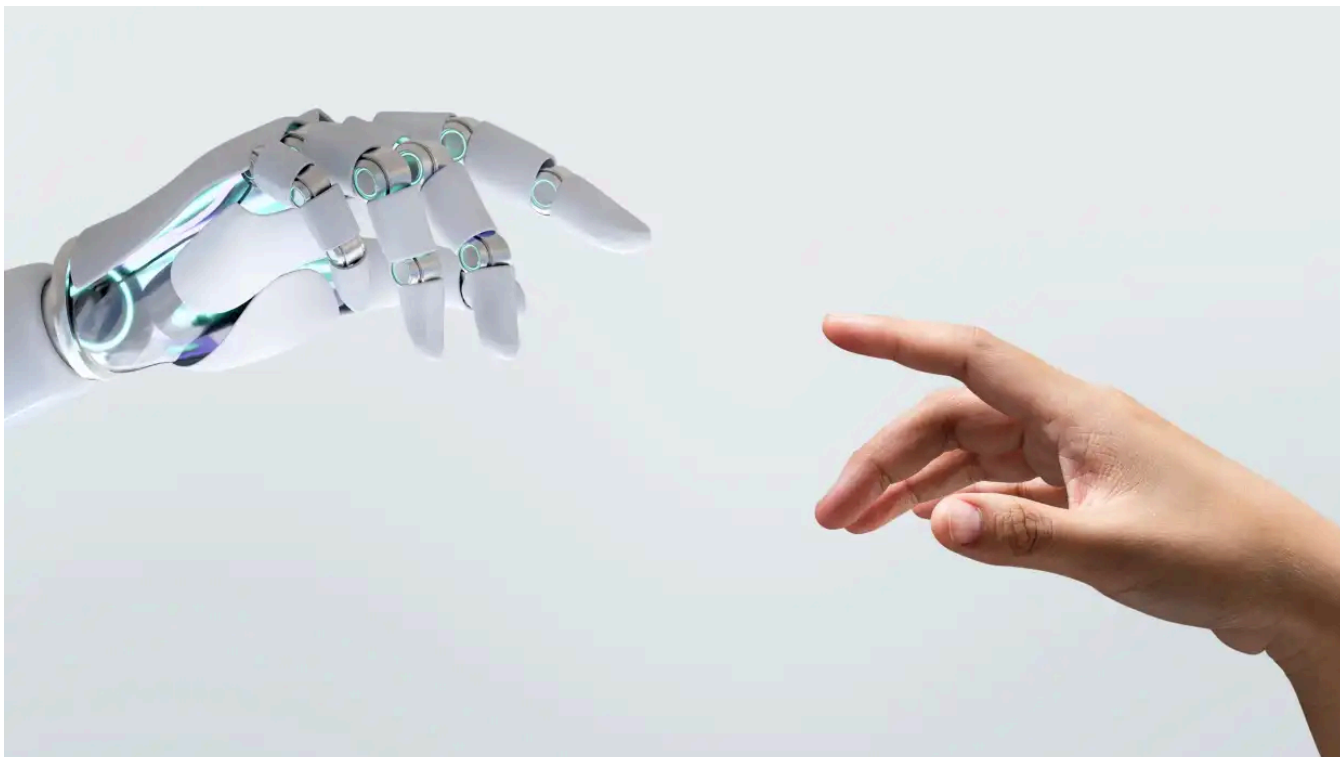
Автор: Швета Шарма
Старший писатель

Человеческий контроль по-прежнему важен, поскольку инструменты на основе ИИ не учитывают риски для безопасности.

Новости

7 августа 2026 года • 3 минуты

Исследователи из 1Password обнаружили, что исправления, сгенерированные с помощью больших языковых моделей, часто не учитывают первопричины, архитектурный контекст и долгосрочные последствия для безопасности при устранении сложных уязвимостей.



Источник: Rawpixel.com / Shutterstock

Согласно исследованию, исправления уязвимостей, созданные с помощью искусственного интеллекта, по-прежнему в значительной степени зависят от проверки человеком, особенно если речь идет о коде, связанном с безопасностью.

Исследователи из компании 1Password опубликовали результаты внутренней оценки, согласно которым исправления, сгенерированные искусственным интеллектом, часто игнорируют более широкие **проблемы** [<https://www.csoonline.com/article/4202381/risk-based-patching-is-the-future-ai-made-it-table-stakes.html>], такие как архитектурные особенности, бизнес-требования, последствия для безопасности и долгосрочная поддержка, несмотря на синтаксическую корректность.

«Мы изучили, что происходит, когда большие языковые модели (БЯМ) генерируют исправления для недавно обнаруженных сложных уязвимостей, — рассказал исследователь из 1Password **Кит Худлет** [<https://www.linkedin.com/in/securingdev/>] в блоге **пост** [<https://1password.com/blog/why-ai-generated-patches-still-require-human-review>]. — Наши данные показывают, что БЯМ в 53,9% случаев создают фиктивные артефакты со встроенными дефектами (FLAWED), когда требуются сложные исправления». В ходе оценки были протестированы исправления, сгенерированные искусственным интеллектом, в шести недавно раскрытых CVE, включая CVE-2026-31431 (**«Ошибка копирования** [<https://www.csoonline.com/article/4169399/new-dirty-frag-exploit-targets-linux-kernel-for-root-access.html>]”), CVE-2026-34197 (**ActiveMQ RCE** [<https://www.csoonline.com/article/4157146/claude-uncovers-a-13%E2%80%91year%E2%80%91old-activemq-rce-bug-within-minutes.html>]), CVE-2026-8512, CVE-2026-45185 (EXIM RCE), CVE-2026-22738 (**SpringAI SpEL RCE** [<https://nvd.nist.gov/vuln/detail/cve-2026-22738>]) и **Gemini CLI RCE** [<https://www.csoonline.com/article/4165470/max-severity-rce-flaw-found-in-google-gemini-cli.html>]) (GHSA-wpqr-6v78-jr5g).

По имеющимся данным, компания 1Password проанализировала 6080 патчей, созданных с помощью ChatGPT-5.5 и Claude Opus 4.8, двух передовых моделей искусственного интеллекта для написания кода, и обнаружила, что лишь чуть более четверти исправлений полностью устраняли уязвимость, не меняя при этом поведение приложения.

«Патчи, которые успешно устраняли уязвимость, но при этом изменяли поведение приложения, применялись в 20,1% случаев», — добавил Худлет.

Закрепить — не то же самое, что зафиксировать

Вместо того чтобы просто проверять, скомпилировался ли исправленный код или прошел ли он автоматизированные тесты, в 1Password заявили, что проверяют каждое сгенерированное исправление на предмет полного устранения уязвимости, сохранения работоспособности приложения и предотвращения новых рисков для безопасности.

Только 26% патчей успешно устранили уязвимость без внесения изменений в приложение, в 49,3% случаев не удалось устранить хотя бы один путь для атаки, в 2,3% случаев исходная уязвимость была устранена, но появилась новая, а в 2,2% случаев проблема не была устранена, а также появилась дополнительная брешь в системе безопасности.

Исследователи также обнаружили, что прохождение заранее определенных тестов может создать более глубокие проблемы. Более трети исправлений, которые изначально казались успешными, были классифицированы как “хрупкие”, потому что они просто блокировали эксплойт proof-of-concept (POC), используемый во время тестирования, вместо устранения основной причины.

Худлет объяснил это на примере патчей SpringAI для уязвимостей CVE. Выяснилось, что модели GPT и Claude генерируют патчи, нацеленные на конкретные символы во входной строке, использованной в представленном им POC, при этом первопричина остается без изменений.

«Если бы защищенный код снова стал доступен при использовании альтернативных входных данных, это привело бы к повторному появлению старой уязвимости в программном обеспечении», — отметил он.

Человеческий контроль остается последним звеном в системе безопасности

1Password утверждает, что эти недостатки связаны с контекстуальным анализом, необходимым для создания готовых к использованию исправлений для системы

безопасности.

Anthropic was reached out to and reportedly recommended keeping humans in the loop. “Patch generation has outpaced patch verification, and the fix is to make verification execution-grounded rather than inspection-based, while keeping domain experts as the final reviewers at current model capabilities,” it was quoted as saying.

1Password also challenged the notion that AI-generated patches are effectively “free.” While the average patch-and-validation cycle cost approximately \$2.11 using ChatGPT-5.5 and \$2.81 using Claude Opus 4.8, Hoodlet argued that the real expense lies in validating whether those patches are secure enough for production.

Artificial Intelligence[https://www.csoonline.com/artificial-intelligence/]

Vulnerabilities[https://www.csoonline.com/vulnerabilities/]

Security[https://www.csoonline.com/security/]

About

⌵

Policies

⌵

More

⌵

Our Network

⌵

